



PLAN DE RESPUESTA A INCIDENTES Y SISTEMA DE GESTION DE LA INFORMACION (SGSI)

Basado en NIST SP 800-61 e ISO/IEC 27001

Ciente	4Geeks Academy
Proveedor del servicio	NexusTrace S.A.S
Analista responsable	Jose Muñoz A
Sistema de referencia	Servidor Debian - IP 192.168.64.9
Marco formativo	NIST SP 800-61 / ISO/IEC 27001
Fecha del documento	11 Marzo 2026
Versión	v1.0
Clasificación	CONFIDENCIAL

Control de Versiones

Version	Fecha	Autor	Descripcion
V1.0	11 Mar 2026	Jose Muñoz A	Version inicial - Plan de Respuesta Incidentes y SGSI basado en NIST SP 800/61 e ISO/IEC 27001

Tipo de incidente	Descripcion
Acceso no autorizado	Uso de credenciales comprometidas para acceder a sistemas
Malware	Instalacion de software malicioso
Exposicion de servicios	Servicios innecesarios accesibles desde red externa
Fuga de informacion	Acceso o divulgación no autorizada de datos
Denegación de servicio	Interrupción de servicios críticos

Introducción

La gestión de incidentes de seguridad constituye un componente fundamental de la estrategia de ciberseguridad de cualquier organización moderna. El incremento de amenazas dirigidas a infraestructuras críticas, servidores web y aplicaciones expuestas a Internet requiere que las organizaciones dispongan de procedimientos estructurados que permitan detectar, contener, erradicar y recuperarse de los incidentes de seguridad de manera eficiente.

El presente documento establece un Plan de Respuesta a Incidentes (Incidente Response Plan) alineado con las mejores practicas descritas en la guía NIST SP 800-61 - Computer Security Incident Handling Guide, y desarrolla un Sistema de Gestión de Seguridad de la Información (SGSI) basado en los principios del estándar ISO/IEC/ 27001.

El objetivo del documento es proporcionar un marco organizacional que permite:

- Detectar incidentes de seguridad
- Responder de forma estructurada ante ataques
- Minimizar el impacto operativo
- Restaurar los servicios afectados
- Prevenir la recurrencia de incidentes similares

2. Alcance del Plan

Este plan aplica a los sistemas de información críticos de la organización, incluyendo:

- Servidores Linux
- Aplicaciones web
- Bases de datos
- Infraestructura de red
- Sistemas de almacenamiento de información

En el contexto del entorno analizado, el plan se enfoca en sistemas que incluyen:

- Servidor we Apache
- Aplicación WordPress

- Base de datos Maria DB
- Servidores de acceso remoto mediante SSH
- Servidores de transferencia de archivos

El plan cubre incidentes relaciones con:

- Accesos no autorizados
- Explotación de vulnerabilidades
- Exposición de servicios
- Compromisos de credenciales
- Modificaciones no autorizadas en el sistema
- Malware o rootkits

3. Clasificación y Severidad de Incidentes

Un incidente de seguridad se define como cualquier evento que comprometa o tenga el potencial de comprometer la confidencialidad, integridad o disponibilidad de los sistemas de información.

Clasificación por tipo:

Nivel	Impacto	Ejemplo
BAJO	Mínimo	Escaneo de puertos
MEDIO	Limitado	Múltiples intentos de acceso fallidos
ALTO	Compromiso de servicio	Explotación de vulnerabilidad
CRÍTICO	Riesgo organizacional	Acceso root no autorizado

Matriz de severidad de incidentes

Rol	Responsabilidad principal
Incident Manager	Coordinar la respuesta al incidente
Analista de seguridad	Analizar el incidente e identificar la causa
Administrador de sistemas	Aplicar medidas correctivas en los sistemas
Equipo de TI	Restaurar servicios afectados
Dirección	Tomar decisiones estratégicas durante incidentes críticos

4. Roles y Responsabilidades

La respuesta a incidentes es gestionada por un equipo especializado denominado CISRT (Computer Security Incident Response Team).

Severidad	Responsable	Acción de escalamiento
BAJO	Analista SOC	Análisis y monitoreo por el analista SOC. Registro del evento.
MEDIO	Administrador de sistemas	Notificación al administrador de sistemas. Revisión de configuraciones y logs.
ALTO	CISRT	Activación del CISRT. Inicio formal del proceso de respuesta a incidentes.
CRITICO	Dirección ejecutiva	Escalamiento inmediato a dirección ejecutiva. Activación de plan de continuidad.

5. Modelo Operativo de Detección (SOC/SIEM)

La organización debe contar con capacidades de monitoreo mediante un Security Operations Center (SOC) o herramientas de gestión de eventos de seguridad (SIEM).

Funciones principales:

- Recolección centralizada de logs
- Correlación de eventos de seguridad
- Detección de anomalías
- Generación de alertas de seguridad
- Análisis de indicadores de compromiso

6. Plan de Respuesta a Incidentes (NIST SP 800-61)

El ciclo de vida de respuesta a incidentes según NIST SP 800-61 se estructura en seis fases secuenciales que garantizan una gestión ordenada, documentada y reproducible de cualquier incidente de seguridad.

6.1 Preparación:

La fase de preparación establece las capacidades necesarias para responder a incidentes de seguridad.

Controles recomendados:

- Monitoreo de logs
- Herramientas de detección de instrucciones
- Inventario de activos
- Políticas de seguridad
- Capacitación del personal

6.2 Identificación:

Consiste en detectar y confirmar la existencia de un incidente de seguridad. Indicadores comunes incluyen:

- Acceso SSH inusuales
- Modificaciones en archivos del sistema
- Actividad anómala en servicios web
- Tráfico de red sospechoso

6.3 Contención

El objetivo es limitar el impacto del incidente

Medidas comunes:

- Bloqueo de direcciones IP sospechosas
- Aislamiento del servidor comprometido
- Desactivación de servicios vulnerables
- Preservación de evidencia digital

6.4 Erradicación

Consiste en eliminar completamente la causa del incidente. Acciones típicas:

- Eliminación de accesos no autorizados
- Eliminación de malware
- Corrección de configuraciones inseguras
- Actualización del sistema
- Cambio de credenciales comprometidas

6.5 Recuperación

La fase de recuperación tiene como objetivo restaurar los sistemas a un estado seguro de operación.

Actividades:

- Restauración de servicios
- Verificación de integridad del sistema
- Validación de funcionamiento de aplicaciones
- Monitoreo reforzado posterior al incidente

En caso de incidentes críticos, la organización debe garantizar la recuperación de los servicios mediante restauración desde copias de seguridad verificadas. Los sistemas restaurados deben ser vigilados antes de reintegrarse a la red productiva para asegurar que no contienen configuraciones vulnerables o artefactos maliciosos.

6.6 Lecciones aprendidas

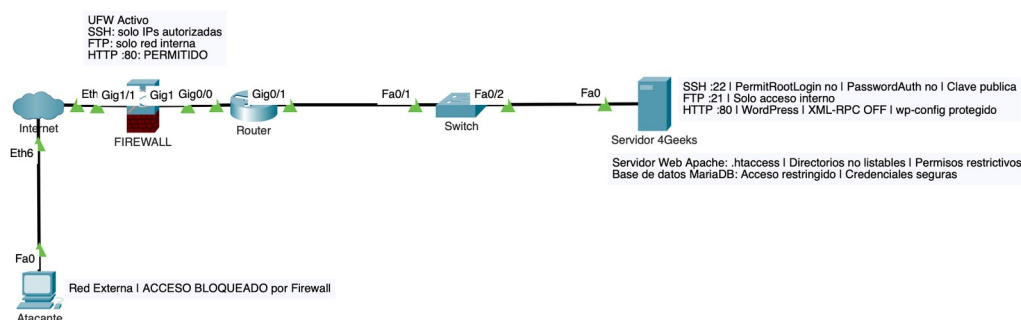
Después de la resolución del incidente se realiza un análisis posterior para identificar mejoras en los controles de seguridad y se documentan.

7. Procedimientos de Escalamiento de Incidentes

Riesgo identificado	Control implementado
Acceso SSH no autorizado	Autenticación segura mediante clave publica, deshabilitar acceso root por SSH
Contraseñas débiles	Política de contraseñas - minimo 12 caracteres, complejidad obligatoria
Servicios expuestos	Firewall con reglas restrictivas (UFW). Bloque de puertos no necesarios
Permisos incorrectos	Gestion de permisos - revision de sudoers, archivos SUID y directorios críticos.

8. Arquitectura Segura de Referencia

La siguiente arquitectura refleja los controles de seguridad implementados en el entorno analizado, organizados en capas defensivas desde el perímetro hasta la base de datos.



9. Protección de Datos

Copias de Seguridad

- Backups completos
- Backups incrementales
- Almacenamiento externo seguro
- Pruebas periódicas de restauración

Cifrado de Información

- Cifrado de discos
- Cifrado de bases de datos
- Uso de HTTPS
- Uso de SSH

Control de Acceso:

- Autenticación multifactor
- Control de acceso basado en roles
- Monitoreo de accesos privilegiados

10. Sistemas de Gestión de Seguridad de la Información (ISO 27001)

10.1 Análisis de Riesgos

PLAN	DO	CHECK	ACT
Definir objetivos de seguridad, identificar riesgos y planificar controles	Implementar los controles y procedimientos planificados	Verificar la efectividad de los controles mediante auditoria y metricas	Corregir desviaciones y mejorar los controles en función de los resultados

10.2 Políticas de Seguridad

- Gestion de contresens
- Control de accesos
- Gestion de incidentes
- Protección de datos
- Contraseñas seguras

10.3 Gestión de Activos

- Servidores
- Bases de datos
- Aplicaciones
- Infraestructura de red
- Información sensible

10.4 Mejora continua

El SGSI opera bajo el modelo de PDCA (Plan-DO-Check-Act), garantizando la mejora continua de los controles de seguridad:

11. Conclusion

La implementación de un Plan de Respuesta a Incidentes basado en NIST SP 800-61 y un SGSI alineado con ISO/IEC 27001 fortalece significativamente la postura de seguridad de la organización.

El incidente analizado en el entorno de referencia - acceso SSH no autorizado como root el 08 de octubre de 2024 - ilustra con precisión la necesidad de contar con un marco estructurado de respuesta: sin procedimientos definidos, sin roles claros y sin controles preventivos activos, el tiempo de detección y contención se extiende considerablemente, aumentando el impacto potencial sobre la confidencialidad, integridad y disponibilidad de los sistemas.

La aplicación del modelo NIST SP 800-61, combinado con los controles de gestión del SGSI bajo ISO/IEC 27001, permite a la organización no solo responder a los incidentes de forma ordenada, sino también aprender de ellos y evolucionar continuamente hacia una postura de seguridad mas resistente.

Jose Muñoz A

Analista de Seguridad - NexusTrace S.A.S

Marzo 2026